MINI PROJECT REPORT

ON

AI PERSONAL STUDY ASSISTANT

Subject: Cybersecurity Fundamentals

Submitted in partial fulfillment of the requirements for the award of the degree of

Bachelor of Technology in Computer Science and Engineering (Artificial Intelligence)

Submitted by:

Muhsina S

Department of Computer Science & Engineering (AI)

TKM Institute of Technology, Karuvelil, Kollam

Submitted to:

Department of Computer Science and Engineering

TKM Institute of Technology

Academic Year: 2026–2027

CYBERSECURITY FUNDAMENTALS

Beginner-to-Intermediate Study Guide | Concepts, Examples, and Practice

Learning objectives: Explain core security principles; identify common attacks; describe basic network and application defenses; distinguish encryption from hashing; and outline how a security team responds to incidents.

1. Introduction to Cybersecurity

1.1 Definition and importance

Cybersecurity is the practice of protecting computers, mobile devices, networks, applications, and data from unauthorized access, misuse, disruption, alteration, or destruction. It combines people, processes, and technology. Security is not only a technical problem: user awareness, clear procedures, and timely decisions matter too.

Why it matters: individuals need to protect identity and accounts; businesses must protect customer information and keep services running; schools and hospitals depend on reliable systems; and public services rely on trustworthy digital infrastructure. A security failure can cause financial loss, privacy violations, downtime, reputational damage, and legal or regulatory consequences.

1.2 The CIA Triad

The CIA Triad is a foundational model for thinking about security requirements:

• Confidentiality — information is visible only to authorized people or systems. Controls include access permissions, encryption, and careful data handling. Example: only a student's authorized instructor can view their marks.

• Integrity — information remains accurate, complete, and changed only in authorized ways. Controls include hashes, digital signatures, version history, and change approvals. Example: a bank balance must not be silently altered.

• Availability — systems and data are accessible when authorized users need them. Controls include backups, redundancy, patching, monitoring, and denial-of-service protection. Example: a hospital booking system should remain usable during busy periods.

A single event may affect more than one property. Ransomware can damage availability by locking files, and may also threaten confidentiality if stolen files are leaked.

1.3 Common cyber threats

Malware

Malware (malicious software) is software designed to harm a device, steal information, spy on activity, or gain unauthorized control. Types include viruses, worms, trojans, spyware, and keyloggers. It may arrive through unsafe downloads, malicious attachments, compromised websites, or unpatched software. Use reputable endpoint protection, update software, restrict privileges, and download only from trusted sources.

Phishing

Phishing is social engineering that tricks people into revealing credentials, sending money, or opening harmful files. Messages may imitate a bank, delivery company, college, or colleague. Warning signs include urgency, unexpected attachments, mismatched sender addresses, unusual payment requests, and links whose destination differs from the displayed text. Verify through a separate trusted channel rather than replying to the suspicious message.

Ransomware

Ransomware is malware that encrypts files or blocks access and demands payment. Some attackers also steal data and threaten to publish it. Defenses include offline or immutable backups, patching, MFA, least-privilege access, email filtering, and tested recovery procedures. Paying does not guarantee data recovery or deletion of stolen copies.

Man-in-the-Middle (MitM)

A MitM attack occurs when an attacker secretly intercepts or alters communication between two parties. Risks include rogue Wi-Fi access points, compromised routers, and certificate warnings ignored by users. HTTPS/TLS, trusted networks, VPNs where appropriate, certificate validation, and avoiding sensitive activity on suspicious networks reduce risk.

Key terminology

• Asset: something valuable, such as data, a laptop, or a service.

• Threat: a potential cause of harm; vulnerability: a weakness that could be exploited.

• Risk: the likelihood and impact of a threat exploiting a vulnerability.

• Attack surface: all the places an attacker might try to enter or affect a system.

• Social engineering: manipulating people into taking unsafe actions.

2. Network Security Fundamentals

2.1 Firewalls

A firewall enforces traffic rules between networks or devices. It may allow or block traffic based on IP addresses, ports, protocols, connection state, or application context. A network firewall can separate an internal network from the internet; a host firewall protects an individual computer. Rules should follow least privilege: allow only traffic that is needed, document exceptions, and review rules periodically. A firewall cannot reliably stop every attack, especially when malicious activity uses permitted traffic or exploits a vulnerable application.

2.2 Virtual Private Networks (VPNs)

A VPN creates an encrypted tunnel between a device and a VPN endpoint over another network. It helps protect traffic from local eavesdroppers and can provide secure remote access to organizational resources. A VPN does not make a user anonymous in every sense, prevent phishing, or guarantee that a device is malware-free. Use an approved VPN, keep the client updated, and still use HTTPS and MFA.

2.3 IDS and IPS

• Intrusion Detection System (IDS): monitors events or network traffic and alerts analysts to suspicious activity. It generally detects and reports rather than automatically blocking.

• Intrusion Prevention System (IPS): detects suspicious activity and can actively block or reject it inline.

• Detection methods include signatures (known patterns) and anomaly/behavior detection (deviations from expected activity).

• False positive: legitimate activity flagged as malicious. False negative: malicious activity that is missed. Both need careful tuning and investigation.

2.4 Secure network architecture

Secure architecture limits how far an attacker can move and reduces unnecessary exposure.

• Segmentation: separate systems into zones, such as guest Wi-Fi, student devices, servers, and administration systems.

• DMZ: a controlled network zone for public-facing services, separated from sensitive internal systems.

• Least privilege: give users and services only the permissions they need.

• Zero Trust: do not automatically trust a user or device because it is inside the network; continuously verify identity, device posture, and access context.

• Secure administration: use MFA, dedicated admin accounts, restricted management interfaces, and encrypted protocols.

• Monitoring and maintenance: centralize logs, patch devices, back up configurations, disable unused services, and regularly test recovery.

Example: A college can place its public website in a DMZ, keep student records in a restricted database network, and allow database access only from the application server—not directly from the internet.

3. Cryptography & Authentication

3.1 Symmetric encryption

Symmetric encryption uses the same secret key to encrypt and decrypt data. It is efficient for large amounts of data. The challenge is securely sharing and protecting the key. Examples of modern symmetric algorithms include AES. Use a secure, authenticated mode provided by a trusted library rather than designing an algorithm yourself.

3.2 Asymmetric encryption

Asymmetric cryptography uses a key pair: a public key that may be shared and a private key that must be protected. It supports key establishment, digital signatures, and some forms of encryption. In a digital signature system, the private key signs and the public key verifies. In practice, secure protocols such as TLS combine asymmetric techniques for authentication or key establishment with symmetric encryption for efficient data transfer.

Comparison: symmetric encryption is usually faster but requires secret-key management; asymmetric cryptography simplifies some key-distribution and signature tasks but is computationally more expensive. Neither method alone proves that a website or message is trustworthy—the keys and identities must also be validated.

3.3 Hashing

A cryptographic hash function maps input data to a fixed-length digest. A good hash function is designed to make it impractical to recover the input from the digest or find two inputs with the same digest. Hashes help check integrity and support digital signatures. Hashing is not encryption: it is not intended to be reversed with a key.

Password storage needs special treatment. Systems should store passwords using a unique salt and a password-hashing algorithm such as Argon2id, bcrypt, or scrypt, configured appropriately. Fast general-purpose hashes such as plain SHA-256 alone are unsuitable for password storage because attackers can test guesses quickly.

3.4 Multi-Factor Authentication (MFA)

MFA requires two or more different factor types: something you know (password or PIN), something you have (security key or authenticator device), and something you are (biometric). Two passwords are not two different factors. MFA reduces the damage caused by stolen passwords. Phishing-resistant passkeys or hardware security keys are generally stronger against fake login pages than SMS codes; SMS may still be better than password-only access.

3.5 Password security

• Use long, unique passwords or passphrases for every account; never reuse a password across important services.

• Use a reputable password manager to generate and store passwords.

• Enable MFA, especially for email, banking, cloud storage, and administrator accounts.

• Do not share passwords or send them through chat or email. Avoid predictable substitutions such as P@ssw0rd.

• Change a password promptly if it is exposed or suspected compromised; routine changes without a reason are less useful than strong unique passwords and MFA.

• Organizations should rate-limit login attempts, detect suspicious sign-ins, protect reset processes, and never store passwords in plaintext.

Remember: encryption protects confidentiality; hashing helps verify integrity or safely represent secrets when used correctly; authentication verifies identity; authorization decides what an authenticated identity may do.

4. Web & Application Security

4.1 OWASP Top 10 overview

The OWASP Top 10 is a widely used awareness list of important web application security risk categories. It is not a complete security checklist, and exact categories can change between editions. The 2021 edition includes:

- Broken Access Control — users can perform actions or view data beyond their permissions.
- Cryptographic Failures — sensitive data is exposed because protection is missing or weak.
- Injection — untrusted input is interpreted as commands or queries.
- Insecure Design — security requirements and threat scenarios were not adequately built into design.
- Security Misconfiguration — unsafe defaults, exposed debug pages, or overly permissive settings.
- Vulnerable and Outdated Components — dependencies contain known weaknesses or are unsupported.
- Identification and Authentication Failures — weak login, session, or identity controls.
- Software and Data Integrity Failures — untrusted updates, dependencies, or pipelines are accepted.
- Security Logging and Monitoring Failures — attacks are not recorded or detected effectively.
- Server-Side Request Forgery (SSRF) — a server is tricked into making unintended requests.

4.2 SQL Injection (SQLi)

SQL injection happens when an application combines untrusted input with a database query in an unsafe way. An attacker may change the meaning of a query to bypass login checks or read, alter, or delete data. The root problem is treating input as executable SQL.

Defenses: use parameterized queries/prepared statements; avoid building SQL by concatenating strings; validate input according to business rules; use least-privileged database accounts; handle errors safely; and test queries during code review and security testing. Input filtering alone is not a reliable replacement for parameterization.

Safe conceptual example: the application sends a query template such as “find user where username equals ?” and supplies the username as a separate parameter. The database treats it as data rather than SQL syntax.

4.3 Cross-Site Scripting (XSS)

XSS occurs when an application causes attacker-controlled script to run in another user's browser. It can be used to impersonate actions, read accessible page data, or alter what the user sees. Common types are stored XSS (saved and later shown), reflected XSS (returned immediately in a response), and DOM-based XSS (unsafe browser-side code updates the page).

Defenses include context-aware output encoding, safe templating frameworks, avoiding unsafe DOM APIs, sanitizing HTML when rich HTML is genuinely needed, and using Content Security Policy as an additional layer. HttpOnly cookies can reduce direct JavaScript access to session cookies but do not prevent every XSS impact.

4.4 Secure coding practices

- Validate input on the server; use allow-lists and sensible length/type limits where possible.
- Use parameterized database queries and safe APIs rather than string concatenation for commands.
- Encode output for its context (HTML, attribute, URL, or JavaScript) and use trusted frameworks correctly.
- Apply authentication and authorization checks on every sensitive server-side operation.
- Store secrets outside source code; rotate exposed credentials and restrict secret access.
- Keep frameworks and dependencies updated; inventory components and remove unused packages.
- Use secure defaults, meaningful error handling, code review, automated tests, and static/dynamic analysis.
- Protect sessions with secure cookie settings, TLS, expiration, and safe logout behavior.
- Threat-model important features before implementation and test security throughout development.

5. Cyber Defense & Incident Response

5.1 Vulnerability assessment vs. penetration testing

A vulnerability assessment identifies, categorizes, and prioritizes weaknesses, often using scanners plus manual validation. It aims to understand the breadth of exposure. A penetration test is an authorized, scoped exercise that safely attempts to exploit selected weaknesses to demonstrate realistic impact. A scan can find many possible issues but may include false positives; a penetration test can demonstrate exploitability but cannot prove that no vulnerabilities exist.

Both require written authorization, a defined scope, safe testing limits, protection of collected data, and a report describing evidence, risk, and remediation. Never test systems without permission.

5.2 Incident Response Lifecycle

1. Preparation — define roles, contact lists, tools, backups, playbooks, and practice exercises.
2. Detection and analysis — review alerts and reports, validate what happened, determine affected assets, and estimate severity.
3. Containment — limit spread or ongoing damage, for example by isolating an affected device or disabling a compromised account.
4. Eradication — remove the cause, such as malware, exposed credentials, or the exploited weakness.
5. Recovery — restore trusted systems from clean backups, patch the weakness, and monitor closely for recurrence.
6. Lessons learned — document the timeline, root cause, response gaps, and concrete improvements.

Evidence handling matters: preserve relevant logs, record actions and times, limit access to collected data, and follow organizational and legal requirements. Decisions should be coordinated with the incident lead; careless shutdowns or deletion of files may destroy useful evidence.

5.3 Basic SOC workflows

A Security Operations Center (SOC) monitors an organization's environment and coordinates detection and response. A typical workflow is:

7. Collect telemetry from endpoints, firewalls, identity systems, servers, cloud services, and applications.

8. Correlate and prioritize events in a SIEM (Security Information and Event Management) platform or related tools.

9. Triage the alert: check severity, affected users/assets, timestamps, source addresses, and whether activity is expected.

10. Enrich evidence using asset inventories, threat intelligence, endpoint alerts, and identity logs.

11. Escalate confirmed or high-risk incidents; follow the approved playbook to contain and investigate.

12. Record findings, actions, and ownership in a case/ticket; verify recovery and close only with documented rationale.

Example: A user reports a suspicious attachment. The SOC checks email logs, endpoint alerts, and sign-in activity; determines whether it was opened; isolates a device if needed; resets compromised credentials; removes the message from other inboxes; and records lessons for prevention.

Practical defensive habits

- Install security updates promptly and remove unsupported software.
- Keep tested backups, including a copy protected from routine account compromise.
- Use MFA, least privilege, endpoint protection, and secure device configurations.
- Train people to report suspicious activity quickly without fear of blame.
- Monitor logs and test incident-response and recovery plans before a real emergency.

6. Review Questions & Practice Quiz

Choose one best answer for each question. Answers and brief explanations follow the questions.

1. Which CIA property is primarily affected when an attacker changes a student's grades without permission?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Authentication

2. What is the most typical purpose of phishing?

- A. Compressing files
- B. Improving Wi-Fi speed
- C. Tricking people into revealing information or taking unsafe actions
- D. Creating backups

3. Which statement best describes a firewall?

- A. It enforces rules on network traffic
- B. It guarantees that all malware is removed
- C. It replaces backups
- D. It stores password hashes

4. What is the main difference between an IDS and an IPS?

- A. IDS always encrypts files
- B. IPS can actively block suspicious traffic, while IDS typically alerts
- C. IDS is a password manager
- D. There is no difference

5. Which option is a different authentication factor from a password?

- A. A second password
- B. A longer password
- C. A hardware security key
- D. A security question whose answer is also a secret you know

6. What is the best defense against SQL injection in database queries?

- A. Hide the submit button
- B. Use parameterized queries
- C. Trust all user input
- D. Show detailed database errors

7. What does a cryptographic hash normally produce?

- A. A fixed-length digest
- B. A private key from any password with no risk
- C. A reversible encrypted file
- D. A VPN tunnel

8. A website displays user-submitted text as executable browser script. Which risk is most relevant?

- A. XSS
- B. DDoS only
- C. Physical theft
- D. Disk fragmentation

9. What should usually happen first after a suspected active security incident is reported?

- A. Delete all logs
- B. Publicly post all details